UNIVERSIDADE DE MOGI DAS CRUZES
SISTEMAS DE INFORMAÇÃO

CASSIANO JESUS SILVA - 11241104826
GUILHERME DA SILVA BONIFÁCIO - 11241103208
YAN BAUMGARTEN COSTA - 11241100266

HEALTH IN SIGHT

Website Informativo sobre Doenças

Instrutor: Fabiano

Mogi Das Cruzes, SP
2026

RESUMO

O presente projeto propõe o desenvolvimento de um sistema web voltado à divulgação de informações sobre doenças e suas respectivas formas de prevenção. A plataforma terá como objetivo facilitar o acesso da população a conteúdos de saúde de maneira simples, organizada e acessível, contribuindo para a disseminação de informações que possam auxiliar na adoção de hábitos preventivos e na busca por atendimento profissional quando necessário.

O sistema permitirá que os usuários consultem informações sobre diferentes doenças, organizadas por categorias, como doenças infecciosas, doenças crônicas e doenças relacionadas a hábitos de vida. Para cada doença, poderão ser disponibilizadas informações gerais, formas de transmissão, principais sintomas, fatores de risco e medidas de prevenção. A plataforma também contará com mecanismos de pesquisa e filtragem, facilitando a localização dos conteúdos desejados.

Além da área destinada aos usuários, o sistema contará com uma área administrativa responsável pelo gerenciamento das informações disponibilizadas. Administradores poderão cadastrar, editar, analisar e excluir conteúdo sobre doenças e categorias, garantindo maior organização e facilidade na manutenção da plataforma.

A proposta busca utilizar a tecnologia como ferramenta de apoio à educação e a conscientização em saúde, disponibilizando informações de forma clara e acessível. O sistema será desenvolvido em conformidade com a Lei Geral de Proteção de Dados Pessoais (LGPD), adotando medidas para garantir a privacidade, a segurança, e também o tratamento adequado dos dados pessoais dos usuários. Ressalta-se que a plataforma terá caráter exclusivamente informativo e educativo, não tendo como finalidade realizar diagnósticos ou substituir a avaliação de profissionais da área da saúde.

SUMÁRIO

1 INTRODUÇÃO 5

1.1 PÚBLICO-ALVO E CONTEXTO NA SAÚDE 5

1.2 ESCOPO DA SOLUÇÃO 5

1.2.1 QUAL O POSSÍVEL NOME DA SOLUÇÃO TECNOLÓGICA NA SAÚDE 5

1.2.2 PROBLEMA DE PESQUISA 5

1.2.3 JUSTIFICATIVA DO PROJETO 5

1.3 OBJETIVOS 6

1.3.1 OBJETIVO GERAL 6

1.3.2 OBJETIVOS ESPECÍFICOS 6

2 REFERENCIAL TEÓRICO 7

3 METODOLOGIA E ARQUITETURA 7

3.1 METODOLOGIA DE DESENVOLVIMENTO 7

3.2 LEVANTAMENTO DE REQUISITOS 8

3.2.1 REQUISITOS FUNCIONAIS 8

3.2.2 REQUISITOS NÃO FUNCIONAIS 9

3.3 PERTINÊNCIA COM A LGPD NO CONTEXTO DA SAÚDE 10

3.4 DIAGRAMA DE ARQUITETURA DO SISTEMA 11

3.5 MATRIZ DE RISCOS ATIVOS E AMEAÇAS 11

3.6 TECNOLOGIAS E FERRAMENTAS UTILIZADAS 14

3.7 ESCOPO DA SOLUÇÃO 15

3.7.1 O QUE FAZ PARTE DO ESCOPO (IN-SCOPE) 15

3.7.2 O QUE ESTÁ FORA DO ESCOPO (OUT-OF-SCOPE) 15

3.8 USUÁRIOS E PERFIS DE ACESSO 16

3.9 MODELO E ENTIDADE-RELACIONAMENTO 17

4 DESENVOLVIMENTO E IMPLEMENTAÇÃO 17

4.1 ESTRUTURA DO PROJETO E CÓDIGO 17

4.2 FUNCIONALIDADES E TELAS 17

4.2.1 TELA HOME 17

4.2.2 TELA CRIAÇÃO DE CONTA 18

4.2.3 TELA DE LOGIN 18

4.2.4 TELA DA AUTENTICAÇÃO 19
4.2.5 TELA DO ADMINISTRADOR 19
4.2.6 TELA DE ATIVAÇÃO DO 2FA 20
4.2.7 TELA COM A REATIVAÇÃO DO 2FA 20
4.2.8 TELA COM A DESATIVAÇÃO DO 2FA 21
4.2.9 TELA SOBRE DADOS E CONTAS 21
4.2.10 TELA DOS LOGS 22
5 TESTES, VALIDAÇÃO E RESULTADOS 23
5.1 ESTRATÉGIAS DE TESTES 23
5.2 RESULTADOS OBTIDOS 23
6 CONSIDERAÇÕES FINAIS 24
6.1 CONCLUSÃO 24
REFERÊNCIAS 24

1 INTRODUÇÃO

1.1 PÚBLICO-ALVO E CONTEXTO NA SAÚDE

O sistema será destinado ao público em geral, especialmente pessoas que buscam informações básicas sobre doenças, seus sintomas, fatores de risco e formas de prevenção. A plataforma terá como objetivo disponibilizar informações de saúde de maneira simples, organizada e acessível, podendo ser utilizada por pessoas de diferentes faixas etárias e níveis de conhecimento sobre o assunto.

No contexto da saúde, muitas pessoas utilizam a internet para buscar informações sobre sintomas, doenças e formas de prevenção, porém podem encontrar conteúdos incorretos, incompletos ou de difícil compreensão. Nesse cenário, o sistema será desenvolvido como uma plataforma educativa, reunindo informações sobre diferentes doenças, seus principais sintomas, formas de transmissão, fatores de risco e medidas preventivas.

A plataforma terá caráter exclusivamente informativo e preventivo, não realizando diagnósticos ou indicando tratamentos. Dessa forma, busca contribuir para a educação em saúde, incentivar hábitos preventivos e conscientizar os usuários sobre a importância de buscar orientação de profissionais de saúde quando necessário. As informações disponibilizadas deverão ser baseadas em fontes confiáveis, contribuindo para que o usuário tenha acesso a conteúdo organizados e de fácil compreensão.

1.2 ESCOPO DA SOLUÇÃO

1.2.1 QUAL O POSSÍVEL NOME DA SOLUÇÃO TECNOLÓGICA NA SAÚDE

O Health in Sight é uma solução tecnológica desenvolvida para disponibilizar informações sobre diferentes doenças, seus principais sintomas, fatores de risco e formas de prevenção. A plataforma tem como objetivo facilitar o acesso da população a informações de saúde de maneira simples, organizada e acessível, contribuindo para a conscientização e a educação em saúde. O sistema terá caráter exclusivamente informativo e preventivo, não realizando diagnósticos ou substituindo a avaliação de profissionais da área da saúde.

1.2.2 PROBLEMA DE PESQUISA

Como disponibilizar informações confiáveis, organizadas e de fácil compreensão sobre doenças, seus principais sintomas, fatores de risco e formas de prevenção, contribuindo para a conscientização da população e para a adoção de medidas preventivas de saúde?

1.2.3 JUSTIFICATIVA DO PROJETO

O desenvolvimento de um portal web para centralizar informações de saúde produzidas por órgãos oficiais e instituições parceiras justifica-se pela dificuldade que a população enfrenta ao buscar orientação confiável, uma vez que esse conteúdo está distribuído em diferentes portais e canais de comunicação, competindo em igualdade de condições com material sem procedência verificada.

A proposta busca reunir essas informações em um único ambiente, com curadoria, organização por tema e atribuição explícita de autoria, tornando a consulta mais simples e confiável. Dessa forma, o sistema contribui para a promoção da saúde, para a prevenção de doenças e para o enfrentamento da desinformação. Justifica-se igualmente sob a perspectiva da segurança da informação, uma vez que o domínio da saúde é um dos que exigem maior rigor no tratamento de dados pessoais, constituindo contexto adequado para a aplicação prática de controles de autenticação, criptografia, auditoria e conformidade normativa.

1.3 OBJETIVOS

1.3.1 OBJETIVO GERAL

Desenvolver um portal web seguro para centralizar e divulgar conteúdos confiáveis sobre prevenção e tratamento de doenças, produzidos por órgãos oficiais e instituições parceiras, facilitando o acesso da população à informação de saúde verificada, sem coleta de dados clínicos dos usuários.

1.3.2 OBJETIVOS ESPECÍFICOS

a) Desenvolver um sistema de cadastro e autenticação dos usuários com autenticação em duas etapas;

b) Organizar os conteúdos por condição de saúde, área, público-alvo e formato do material;

c) Implementar uma ferramenta de pesquisa e filtros sobre o acervo;

d) Conter os principais requisitos de segurança necessários para esse tipo de plataforma com base na LGPD;

e) Assegurar a atribuição da fonte oficial de cada conteúdo publicado, com redirecionamento para o material original;

f) Aplicar o princípio da minimização, restringindo a coleta de dados pessoais ao estritamente necessário para a autenticação.

2 REFERENCIAL TEÓRICO

A revisão de literatura que fundamenta este projeto articula três eixos técnicos — proteção de credenciais, autenticação multifator e integridade de registros de auditoria — além do enquadramento legal imposto pela LGPD.

No armazenamento de senhas, a literatura e as recomendações de mercado convergem para o uso de funções de derivação de chave com custo de memória e tempo ajustável, em substituição a funções de hash genéricas como SHA-256. O algoritmo Argon2id, padronizado na RFC 9106 (BIRYUKOV et al., 2021), é a recomendação atual do OWASP Password Storage Cheat Sheet (OWASP FOUNDATION, 2023) por resistir tanto a ataques por dicionário paralelizados em GPU quanto a ataques por canal lateral, razão pela qual foi adotado neste projeto, com salt único por usuário.

A autenticação em duas etapas segue o padrão TOTP (Time-based One-Time Password), especificado na RFC 6238 (M'RAIHI et al., 2011), que deriva códigos numéricos de validade curta a partir de um segredo compartilhado e do relógio do sistema. O NIST SP 800-63B (NIST, 2017) recomenda esse fator adicional como mitigação eficaz contra o reuso de credenciais vazadas em outros serviços (credential stuffing).

A trilha de auditoria implementada segue o modelo de logs encadeados por hash proposto por Schneier e Kelsey (1999): cada evento incorpora criptograficamente o hash do evento anterior, de modo que qualquer alteração retroativa de um registro quebra a cadeia de verificação dos registros seguintes — propriedade central para a evidência de integridade exigida pelo item 5.3 do check-list do projeto.

Por fim, o tratamento de dados pessoais observa a Lei Geral de Proteção de Dados Pessoais (BRASIL, 2018), que classifica dados de saúde como sensíveis (art. 5º, II) e estabelece, no art. 6º, III, o princípio da necessidade como limite à coleta. A decisão de projeto de não coletar dados clínicos do usuário — apenas os dados cadastrais mínimos exigidos para a autenticação — decorre diretamente desse princípio.

3 METODOLOGIA E ARQUITETURA

3.1 METODOLOGIA DE DESENVOLVIMENTO

O desenvolvimento seguiu um processo incremental, organizado nos cinco blocos de requisitos definidos pelo check-list da disciplina: (1) autenticação e gestão de credenciais, (2) recuperação de senha, (3) criptografia e comunicação segura, (4) conformidade com a LGPD e (5) auditoria e logs. Cada bloco só foi considerado concluído após a implementação, a escrita dos testes automatizados correspondentes e a validação manual via front-end.

O controle de versão foi feito em Git, com repositório hospedado no GitHub e histórico de commits organizados por etapa de trabalho, permitindo rastrear a evolução de cada requisito.

A divisão de tarefas entre os três integrantes foi acompanhada por um quadro Kanban, com colunas para tarefas pendentes, em andamento e concluídas.

Em ambiente de desenvolvimento, a aplicação roda sobre SQLite; em produção, sobre MySQL gerenciado pela Aiven, com conexão TLS obrigatória. A suíte de testes automatizados (Django TestCase) roda sempre contra um banco de dados em memória, isolado do ambiente de produção, e é executada antes de cada commit relevante. O deploy é feito no Render a partir da branch principal do repositório.

3.2 LEVANTAMENTO DE REQUISITOS

3.2.1 REQUISITOS FUNCIONAIS

RF	DESCRIÇÃO
[RF01]	**Autenticação em Duas Etapas:** O sistema deve permitir que o usuário ative a validação via Autenticação de dois Fatores (2FA) e, quando ativada, exigi-la após a primeira autenticação.
[RF02]	**Encerramento de Sessão (Logout):** O sistema deve oferecer a opção de logout com invalidação imediata da sessão do usuário.
[RF03]	**Recuperação de Senha:** O sistema deve permitir que o usuário solicite a redefinição/recuperação de senha via e-mail ou código.
[RF04]	**Consentimento LGPD:** O sistema deve solicitar e registrar o consentimento explicito do usuário armazenando a data, versão e finalidade de uso de dados.
[RF05]	**Revogação e Consentimento:** O sistema deve oferecer interface para que o usuário revogue o consentimento concedido a qualquer momento.
[RF06]	**Consulta aos Dados do Titular:** O sistema deve permitir que o usuário consulte a listagem completa dos seus dados pessoais armazenados.
[RF07]	**Exportação de Dados:** O sistema deve oferecer funcionalidade para o usuário exportar seus dados pessoais em formato estruturado.

[RF08]	**Exclusão de Dados (Direito ao Esquecimento):** O sistema deve permitir que o usuário solicite a exclusão definitiva dos seus dados pessoais.
[RF09]	**Registro de Logs de Autenticação:** O sistema deve registrar eventos de login, falhas de acesso e uso do 2FA.

Fonte: Elaborado pelos autores.

3.2.2 REQUISITOS NÃO FUNCIONAIS

RNF	DESCRIÇÃO
[RNF01]	**Segurança:** As senhas devem ser armazenadas utilizando algoritmos de hash seguro, com salt criptográfico único por usuário e parâmetros de custo justificados.
[RNF02]	**Segurança:** As sessões ativas dos usuários devem expirar automaticamente após o tempo limite de inatividade.
[RNF03]	**Segurança:** O sistema deve possuir mecanismos de proteção contra ataques de força bruta (como rate limit, bloqueio temporário ou atraso).
[RNF04]	**Segurança:** Os tokens de recuperação de senha devem ser gerados de forma criptograficamente segura, possuir tempo de expiração curto e ser invalidados após o uso ou após o tempo de expiração.
[RNF05]	**Auditoria:** O sistema deve registrar em logs todas as solicitações de recuperação de senha, junto do resultado de sucesso ou falha do processo.
[RNF06]	**Comunicação:** Todo o tráfego de dados deve ser protegido obrigatoriamente via TLS/HTTPS, bloqueando conexões não seguras.

[RNF07]	**Criptografia:** Dados sensíveis no banco de dados devem ser criptografados em repouso com algoritmo adequado e chaves protegidas
[RNF08]	**LGPD/Privacidade:** A arquitetura da base de dados deve seguir o princípio da minimização, associando e limitando cada dado coletado a uma finalidade estrita.
[RNF09]	**Auditoria:** Os arquivos e registros de logs de auditoria devem ter proteção contra alteração, exclusão ou adulteração indevida.

Fonte: Elaborado pelos autores.

3.3 PERTINÊNCIA COM A LGPD NO CONTEXTO DA SAÚDE

A Lei Geral de Proteção de Dados Pessoais, em seu artigo 5º, inciso II, classifica os dados referentes à saúde como dados pessoais sensíveis, submetendo-os ao regime mais restritivo do artigo 11. Diante desse risco, o projeto adota o princípio da necessidade, previsto no artigo 6º, inciso III: a plataforma não coleta dados clínicos de seus usuários, e o acervo de conteúdo é público e idêntico para todos os visitantes, sem personalização baseada em condição de saúde. A única exceção é a função opcional de guardar materiais: como guardar um material sobre uma doença indica interesse por um tema de saúde, esse registro é tratado como dado pessoal sensível (art. 5º, II) e só é gravado mediante consentimento específico para essa finalidade (art. 11, I), que pode ser revogado a qualquer momento, apagando os materiais guardados.

Os dados pessoais efetivamente tratados limitam-se aos necessários para a autenticação e para a segurança do próprio sistema: nome completo e endereço de e-mail para identificação e acesso; senha armazenada exclusivamente como hash criptográfico; segredo de autenticação em duas etapas, cifrado em repouso; a trilha de auditoria dos eventos de autenticação, com endereço IP, navegador (user agent), identificador da conta e data e hora, para rastreabilidade; e o registro de consentimento, com data, versão do termo e finalidade aceita. Além disso, ao abrir o site, o endereço IP do visitante é enviado ao Google Fonts, serviço que fornece a fonte da interface. A aplicação é hospedada no Render, em Oregon, e o banco de dados no Aiven, em São Francisco, ambos nos Estados Unidos, o que caracteriza transferência internacional de dados pessoais, sujeita às hipóteses do art. 33 da LGPD.

Aceitação dos termos de uso da plataforma e da política de privacidade, com registro da versão aceita, e atendimento às requisições dos titulares que solicitarem a consulta, a exportação, a correção ou a exclusão dos seus dados, bem como a revogação do consentimento a qualquer momento, conforme o artigo 18 da referida lei.

Medidas de segurança aptas a proteger dados pessoais de acesso não autorizado, prevenindo e limitando o acesso conforme a função de cada colaborador, praticando auditorias para fins de rastreabilidade dos logs de acesso. Os registros de auditoria são preservados de forma pseudonimizada após a exclusão da conta, com fundamento no artigo 16, incisos I e III.

3.4 DIAGRAMA DE ARQUITETURA DO SISTEMA

O sistema segue uma arquitetura monolítica: uma única aplicação Django, hospedada no Render, concentra a camada de apresentação (templates), a lógica de negócio e o acesso a dados, comunicando-se com um banco de dados MySQL gerenciado pela Aiven exclusivamente por conexão cifrada (TLS). Não há camadas adicionais como API Gateway, filas de mensagens ou um serviço de gerenciamento de chaves dedicado (KMS): as responsabilidades de segurança — hashing de senha, validação do segundo fator, bloqueio por força bruta e geração da trilha de auditoria — são implementadas como módulos e middlewares internos da própria aplicação Django, conforme ilustrado na figura a seguir.

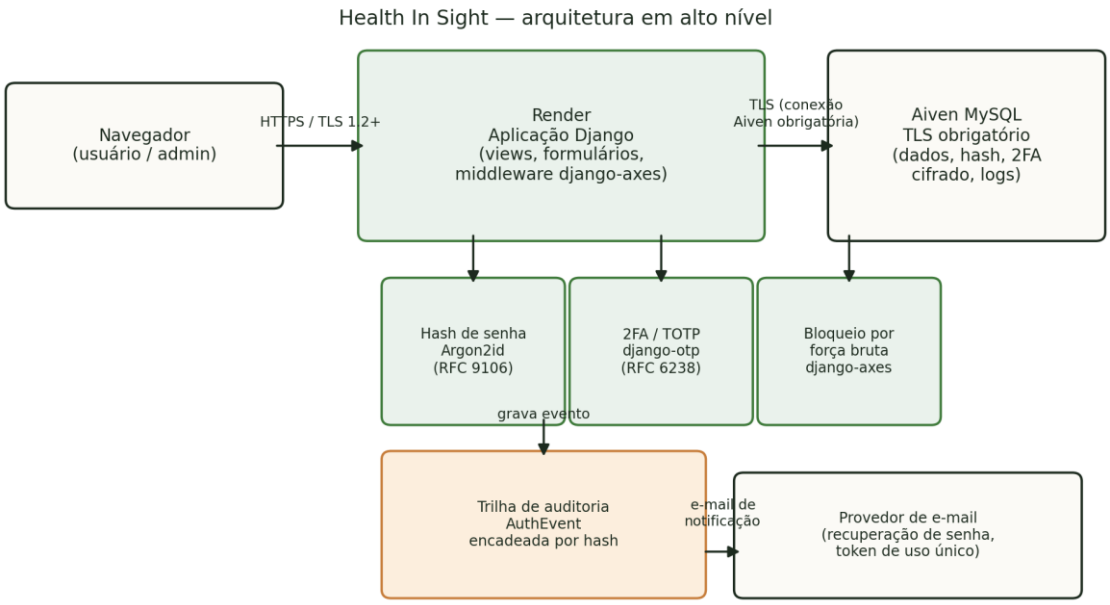


Figura 1 — Arquitetura em alto nível do Health In Sight.

3.5 MATRIZ DE RISCOS ATIVOS E AMEAÇAS

Os principais ativos protegidos pelo sistema são: o banco de dados de usuários (Aiven MySQL), o hash das senhas (Argon2id), o segredo do segundo fator (TOTP), a SECRET_KEY da aplicação Django, a sessão autenticada do usuário e a própria trilha de auditoria. A tabela a seguir aplica o modelo STRIDE a esses ativos, associando cada ameaça identificada à contramedida efetivamente implementada no sistema entregue — e não a controles genéricos de mercado.

Categoria STRIDE	Ameaça identificada	Ativo afetado	Contramedida implementada
Spoofing	Preenchimento de credenciais vazadas ou força bruta no login	Conta do usuário	django-axes: bloqueio após 5 tentativas, combinando conta e endereço IP (AXES_LOCKOUT_PARAMETERS), por 5 minutos no primeiro bloqueio e o dobro a cada repetição no mesmo dia.
Spoofing	Invasor com a senha de um membro da equipe tenta entrar no painel /admin/ sem o segundo fator (R01)	Painel administrativo, acervo e dispositivos 2FA	O admin.site é um OTPAdminSite (django-otp): o painel só abre para a equipe depois do código TOTP confirmado na sessão. Conta da equipe sem 2FA não entra no site, e o cadastro de dispositivos 2FA saiu do painel.
Spoofing	Password spraying: testar uma senha comum em muitas contas a partir do mesmo IP, sem atingir o limite por conta e IP (R05)	Contas de usuário	Limite de envios por IP e no total no login (django-ratelimit), além do bloqueio por conta e IP do django-axes, que passou a ser progressivo.
Spoofing	Quem encontra uma sessão aberta desliga o 2FA ou testa senhas na tela de exclusão da conta (R12)	Conta do usuário, segundo fator	Desativar o 2FA pede a senha e um código. A exclusão da conta e a desativação do 2FA bloqueiam depois de 5 confirmações erradas em 15 minutos.
Tampering	Alteração retroativa de um registro da trilha de auditoria	Trilha de auditoria	Encadeamento por hash: cada evento grava o hash do evento anterior; qualquer alteração quebra a cadeia, detectável pelo comando verificar_logs.
Repudiation	Usuário negar ter realizado login, tentativa de acesso ou exclusão de conta	Trilha de auditoria	Registro de IP de origem, data/hora e tipo de evento para cada evento de autenticação, capturado via signals do Django — inclusive eventos disparados pelo painel administrativo.
Information Disclosure	Extração do banco de dados expondo senhas ou	Hash de senha, segredo TOTP	Senha armazenada apenas como hash Argon2id (irreversível); segredo do TOTP cifrado em repouso.

	segredos de 2FA		
Information Disclosure	Descobrir se um e-mail tem conta pela resposta do cadastro (R08)	Contas de usuário	O cadastro responde igual para e-mail novo ou já cadastrado. A conta só é ativada pelo link enviado ao e-mail, e o dono do endereço recebe aviso da tentativa.
Information Disclosure	Token de recuperação de senha vazando pelo histórico do navegador ou pelo cabeçalho Referer (R13)	Conta do usuário	O link só confere o token e redireciona para um endereço sem ele; a sessão guarda apenas o identificador do registro.
Denial of Service	Sobrecarga do endpoint de login com tentativas repetidas	Disponibilidade do serviço de autenticação	Limite de envios por IP e no total no login, na verificação do código, no cadastro e na recuperação de senha (resposta 429), somado ao bloqueio do django-axes.
Denial of Service	Esgotamento de memória: muitos logins simultâneos com e-mails aleatórios, cada um calculando um Argon2id de 64 MiB no único worker (R03)	Disponibilidade da autenticação	Os mesmos limites por IP e no total reduzem quantos Argon2id são calculados ao mesmo tempo. O Gunicorn roda com 2 workers (WEB_CONCURRENCY no Render).
Elevation of Privilege	Usuário comum tentando acessar rotas administrativas ou dados de outro titular	Painel administrativo, dados de outros usuários	Checagem de permissão de administrador em toda view administrativa; nenhum perfil tem permissão para alterar ou excluir registros da trilha de auditoria.

Fonte: Elaborado pelos autores.

A matriz a seguir classifica os 15 riscos identificados na avaliação de segurança do repositório por probabilidade e impacto. O nível é o produto das duas notas: probabilidade Baixa (1), Média (2) ou Alta (3) vezes impacto Baixo (1), Médio (2), Alto (3) ou Severo (4); até 2 é Baixo, de 3 a 4 Médio, de 6 a 8 Alto e 9 ou mais Crítico. Os pilares são confidencialidade (C), integridade (I) e disponibilidade (D). A última coluna mostra a situação de cada risco depois das correções de outubro de 2026; “Parcial” indica que a correção no código está pronta, mas ainda depende de configuração nos painéis do Render, do Aiven ou do GitHub.

ID	Risco	Pilar	Probabilidade	Impacto	Nível	Situação

R01	2FA ausente no /admin/: a senha de alguém da equipe abre o painel, o acervo e os dispositivos 2FA	C, I	Média	Severo	Alto	Corrigido
R02	Banco e chave AES de produção nas máquinas de toda a equipe; o banco aceita conexão de qualquer IP	C, I	Média	Severo	Alto	Parcial
R03	Esgotamento na autenticação: Argon2 de 64 MiB sem limite por IP, um único worker e banco com 76 conexões e 1 GB de disco	D	Alta	Médio	Alto	Corrigido
R04	Sem plano de continuidade num banco gratuito de nó único, sem SLA e sujeito a desligamento por inatividade	D	Média	Alto	Alto	Parcial
R05	Tomada de conta por senha: 2FA opcional e bloqueio por conta e IP contornável	C	Média	Médio	Médio	Corrigido
R06	Trilha de auditoria recalculável, truncável e fail-open	I	Baixa	Alto	Médio	Em aberto
R07	Direitos do titular incompletos, retenção indefinida da trilha e transferência para os EUA não informada	C	Média	Médio	Médio	Corrigido
R08	Enumeração de contas e cadastro sem confirmação de e-mail	C	Alta	Baixo	Médio	Corrigido
R09	Verificação de identidade do MySQL não fixada no código	C, I	Baixa	Alto	Médio	Corrigido
R10	Dado de saúde (MaterialSalvo) e IPs em claro no banco	C	Baixa	Alto	Médio	Risco aceito
R11	Cadeia de entrega: actions mutáveis, testes fora do CI e deploy sem esperar o CI	I	Baixa	Alto	Médio	Corrigido
R12	Desativar o 2FA e excluir a conta sem reautenticação forte	C, D	Baixa	Médio	Baixo	Corrigido
R13	Token de recuperação no caminho da URL	C	Baixa	Médio	Baixo	Corrigido
R14	Sem CSP nem no-store; IP do visitante enviado ao Google Fonts	C	Média	Baixo	Baixo	Corrigido
R15	Entrada não validada (erro 500) e aceite conferido só no navegador	I, D	Média	Baixo	Baixo	Corrigido

Fonte: Elaborado pelos autores a partir da avaliação de segurança do repositório (out. 2026).

Aceitação formal do risco R10. O registro dos materiais guardados (MaterialSalvo) indica interesse por um tema de saúde e é dado pessoal sensível, mas fica no banco sem cifragem própria da aplicação. A equipe aceita esse risco residual pelos seguintes motivos: o registro guarda apenas qual material e quando, sem nenhuma anotação da pessoa; só é gravado com consentimento específico para essa finalidade, que pode ser revogado a qualquer momento e apaga os registros; o banco só é acessado por conexão cifrada que confere o certificado e o nome do servidor; e o disco do serviço é cifrado pelo próprio Aiven, que usa cifragem de volume

completo (LUKS) com uma chave aleatória por instância e também cifra os backups (AIVEN, 2026). Cifrar o campo na aplicação impediria as consultas que listam e removem os materiais de cada conta, com ganho pequeno diante dessas proteções. Os endereços IP da trilha de auditoria seguem a mesma decisão: precisam ser legíveis para a análise de incidentes e são apagados depois do prazo de retenção de seis meses. O risco será reavaliado se a função passar a guardar mais do que o material e a data.

3.6 TECNOLOGIAS E FERRAMENTAS UTILIZADAS

Para a execução deste projeto foi necessário um conjunto de ferramentas e tecnologias. A seguir estão as linguagens de programação e ferramentas utilizadas no desenvolvimento do projeto:

a) HTML5;
b) CSS3;
c) JAVASCRIPT;
d) PYTHON;
e) MYSQL.

3.7 ESCOPO DA SOLUÇÃO

3.7.1 O QUE FAZ PARTE DO ESCOPO (IN-SCOPE)

O escopo do projeto contempla as seguintes funcionalidades:

a) Cadastro e login dos usuários com autenticação em duas etapas (TOTP), obrigatória para as contas da equipe. O painel administrativo (/admin/) também exige o código TOTP, pelo OTPAdminSite do django-otp (risco R01 corrigido), e quem perde o celular entra com um dos códigos de reserva;

b) Busca e filtros por condição de saúde, área, público-alvo e formato do material;

c) Registro dos eventos de autenticação em trilha de auditoria protegida contra alteração;

d) Criação de janela para a exibição do conteúdo;

e) Segurança com Hash e Criptografia;

f) Sessões com tempo de expiração.

3.7.2 O QUE ESTÁ FORA DO ESCOPO (OUT-OF-SCOPE)

Não fazem parte do escopo deste projeto:

a) Diagnóstico, triagem de sintomas ou qualquer orientação clínica individualizada;

b) Prescrição de medicamentos ou de tratamentos;

c) Teleconsulta, agendamento de consultas e atendimento por profissionais de saúde;

d) Prontuário eletrônico, armazenamento de exames, laudos ou histórico clínico;

e) Coleta de dados clínicos do usuário, como condições, sintomas e medicamentos em uso;

f) Produção própria de conteúdo médico, cabendo à plataforma apenas a curadoria e a divulgação de material de fontes oficiais;

g) Comercialização de medicamentos, produtos ou serviços de saúde;

h) Integração com sistemas de saúde públicos ou privados, tais como prontuários hospitalares ou bases de operadoras.

3.8 USUÁRIOS E PERFIS DE ACESSO

Os perfis de usuários que vão interagir com o sistema são o visitante, o usuário cadastrado, os administradores de TI e o encarregado pelo tratamento de dados pessoais.

Permissões:

Visitante: Consulta ao acervo público de conteúdos, sem necessidade de inserção de dados;

Usuário cadastrado: Consulta ao acervo, gestão da própria conta (senha e 2FA), uso da função opcional de guardar materiais e consulta, exportação e exclusão dos próprios dados;

Administradores de TI: Criação, alteração, análise e exclusão de conteúdos na plataforma, gestão da infraestrutura, validação e configurações de rastreamento de URLs, manutenção das chaves criptográficas, direito para analisar o registro de auditoria e acesso ao banco de dados.

Encarregado pelo tratamento de dados pessoais: Não possui perfil próprio no sistema; as requisições dos titulares são atendidas pelas funções de autoatendimento da área “Meus dados”.

Restrição de acesso:

Usuários: Não é permitido manipular conteúdo, configurações ou dados de terceiros, permitido somente a leitura do Website.

Nenhum perfil possui permissão para alterar ou excluir registros da trilha de auditoria.

Administradores de TI: Não é permitido excluir o próprio perfil caso seja o único no sistema.

3.9 MODELO E ENTIDADE-RELACIONAMENTO

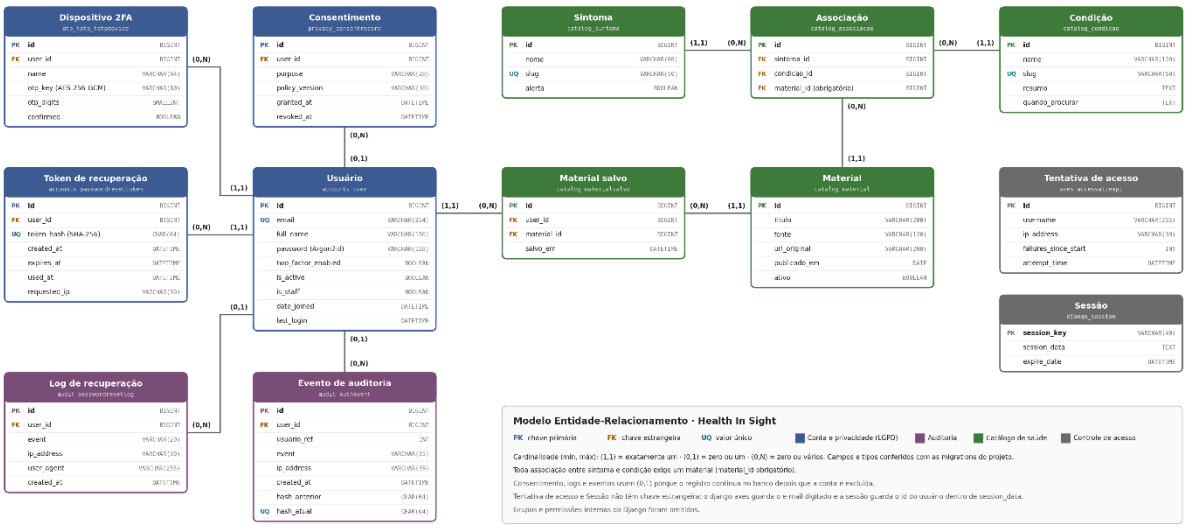


Figura 2 — Modelo entidade-relacionamento do banco, com as 13 tabelas do sistema.

4 DESENVOLVIMENTO E IMPLEMENTAÇÃO

4.1 ESTRUTURA DO PROJETO E CÓDIGO

O projeto é organizado em aplicações Django separadas por responsabilidade — por exemplo, uma app para contas e autenticação de usuários, uma app para o acervo de conteúdos de saúde e uma app para a trilha de auditoria — favorecendo a coesão de cada módulo e facilitando a leitura do código por requisito.

A configuração da aplicação é orientada por variáveis de ambiente: quando a variável DB_HOST não está definida, a aplicação cai automaticamente para SQLite (usado em desenvolvimento e nos testes automatizados); quando definida, conecta-se ao MySQL da Aiven com TLS obrigatório, usado em produção.

Comandos de gerência customizados (management commands) foram criados para dar suporte à trilha de auditoria — verificar_logs, que recalcula a cadeia de hash e aponta o primeiro elo quebrado, e analisar_logs, que resume os eventos registrados por período. O código de segurança (hashing, 2FA, bloqueio por força bruta e trilha de auditoria) é comentado explicando a lógica implementada, conforme exigido pelo edital.

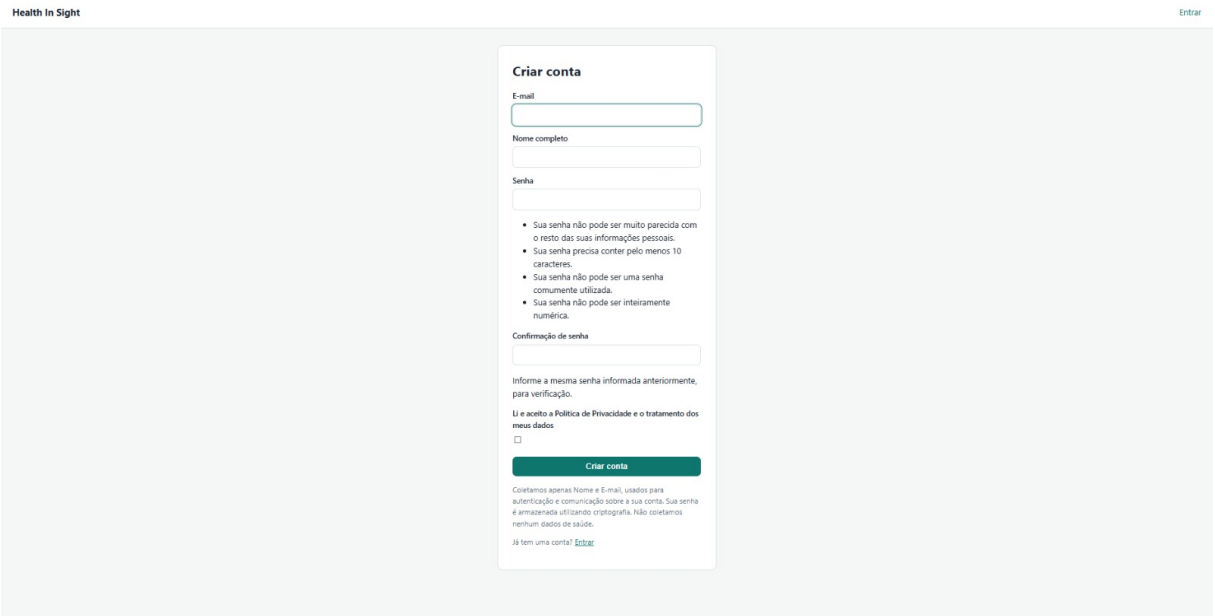
4.2 FUNCIONALIDADES E TELAS

4.2.1 TELA HOME



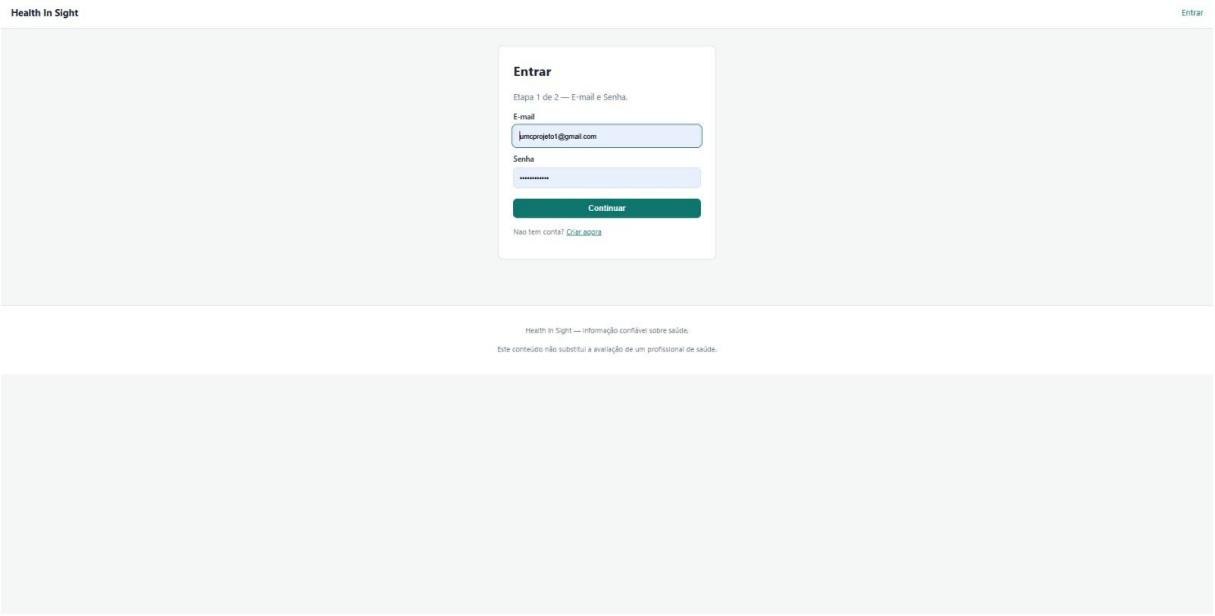
Legenda: Tela inicial, sem necessidade de login para o usuário comum: título de posicionamento e reforço de que o conteúdo não substitui a avaliação de um profissional de saúde contendo as informações do site.

4.2.2 TELA CRIAÇÃO DE CONTA



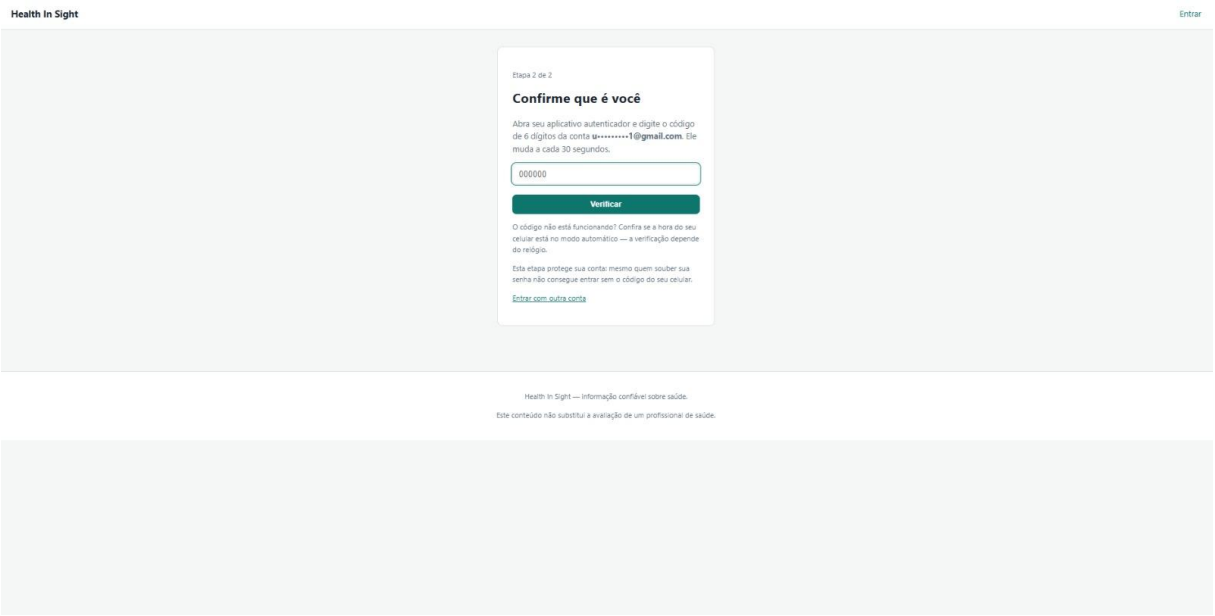
Legenda: Formulário de criação de conta, coletando apenas e-mail, nome e senha; a tela lista as regras de senha e informa explicitamente que nenhum dado de saúde é coletado, antes de criar a conta, aparece um pop up, explicando sobre os dados, sendo necessário ler e concordar para continuar com a criação de uma conta.

4.2.3 TELA DE LOGIN



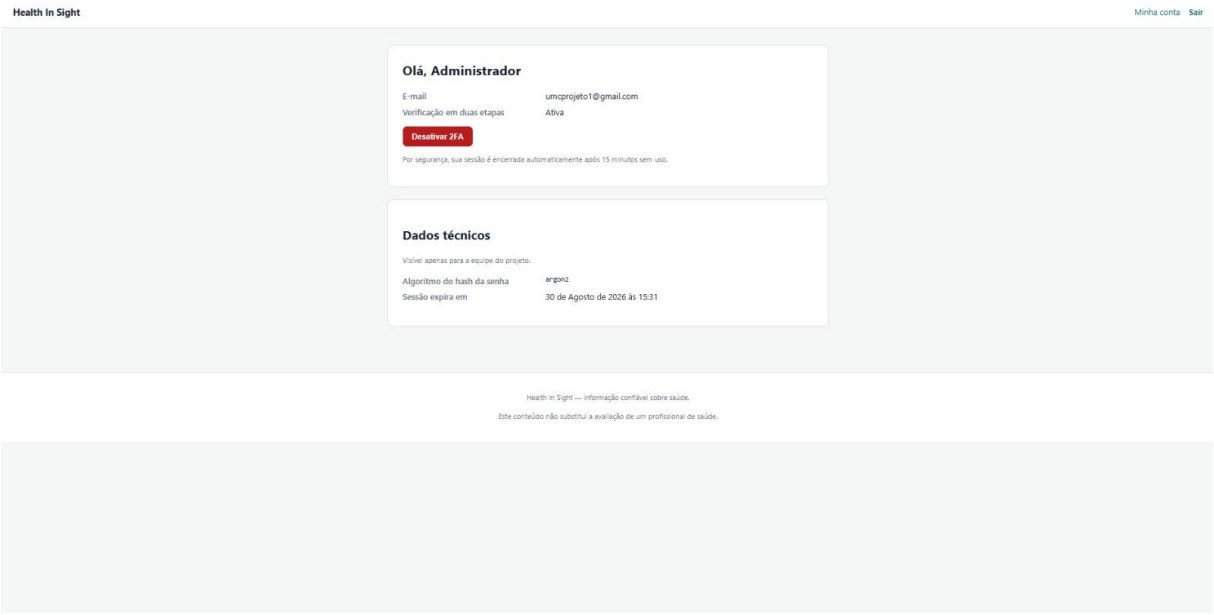
Legenda: Etapa 1 de 2 do login: validação de e-mail e senha antes de liberar o desafio do segundo fator.

4.2.4 TELA DA AUTENTICAÇÃO



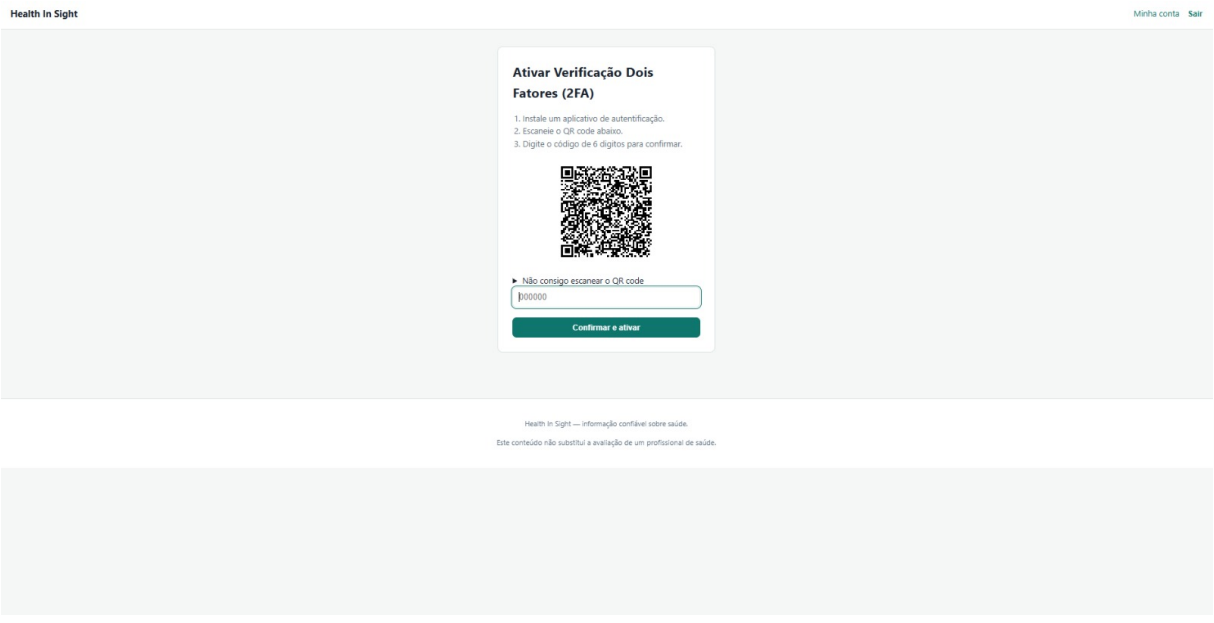
Legenda: Etapa 2 de 2 do login: desafio do código TOTP de 6 dígitos, com o e-mail da conta parcialmente mascarado na tela.

4.2.5 TELA DO ADMINISTRADOR



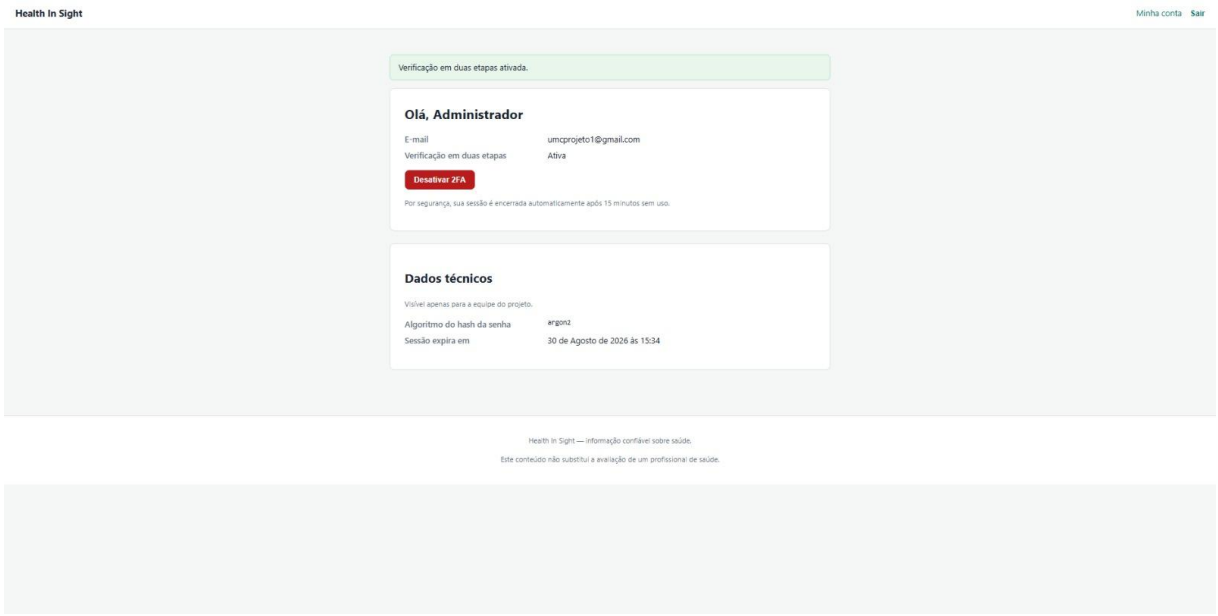
Legenda: Painel do administrador, com o status da verificação em duas etapas e um bloco de dados técnicos (algoritmo de hash da senha e horário de expiração da sessão), visível apenas para a equipe do projeto.

4.2.6 TELA DE ATIVAÇÃO DO 2FA



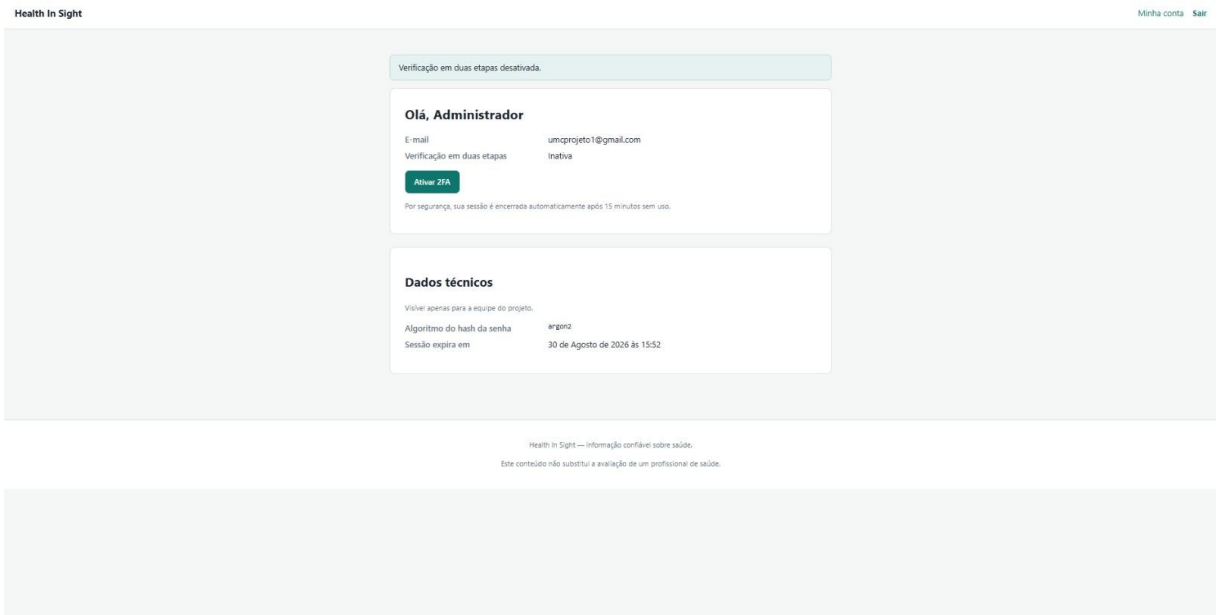
Legenda: Ativação do 2FA: exibição do QR Code a ser escaneado pelo aplicativo autenticador e campo para confirmar o primeiro código gerado.

4.2.7 TELA COM A REATIVAÇÃO DO 2FA



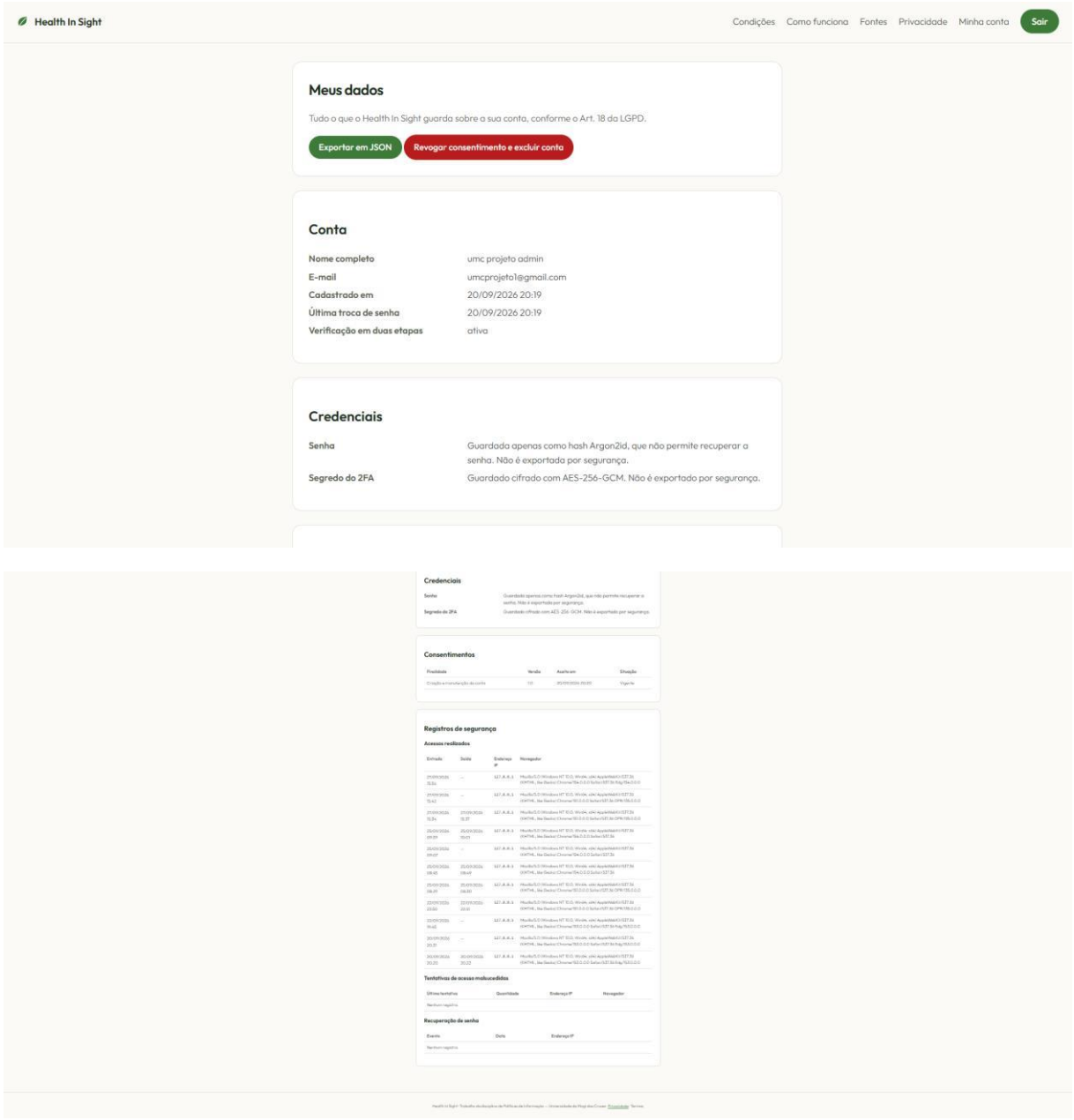
Legenda: Confirmação de reativação do 2FA ("Verificação em duas etapas ativada."), com o painel já refletindo o novo status.

4.2.8 TELA COM A DESATIVAÇÃO DO 2FA



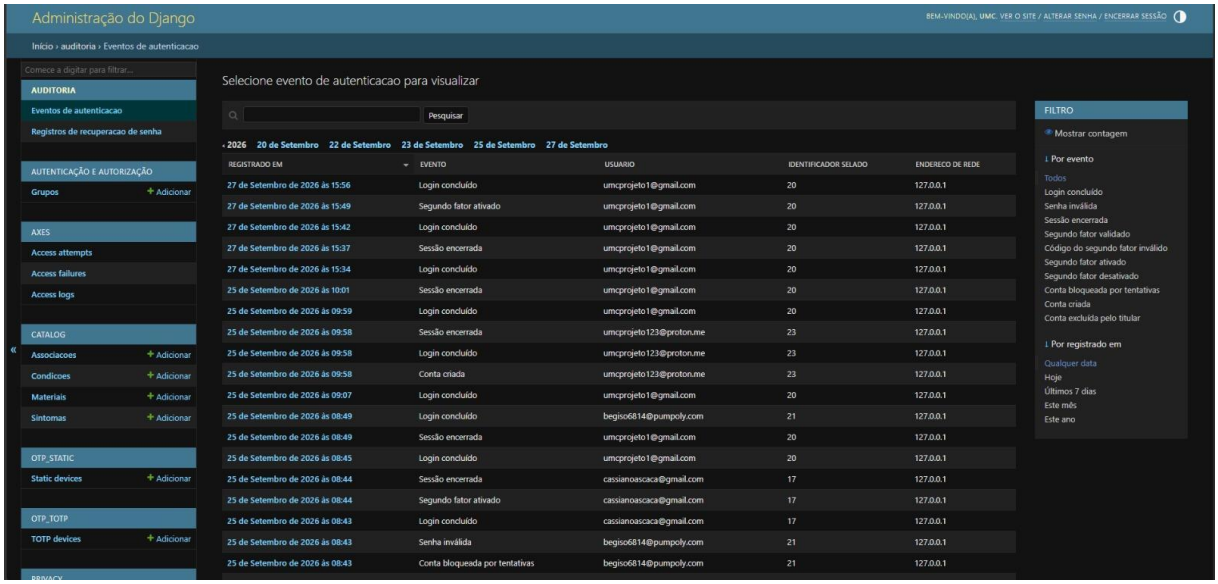
Legenda: Confirmação de desativação do 2FA ("Verificação em duas etapas desativada."), com o painel voltando a oferecer a opção "Ativar 2FA".

4.2.9 TELA SOBRE DADOS E CONTAS



Legenda: Esta tela e referente ao usuário administrador do sistema, aparecendo as informações importantes como, credenciais, consentimentos, os registros de segurança, tentativas de acesso e recuperações de senha.

4.2.10 TELA DOS LOGS



Legenda: Esta tela se refere aos logs, onde estão registrados todos os acessos no site, como e possível visualizar na imagem acima.

5 TESTES, VALIDAÇÃO E RESULTADOS

5.1 ESTRATÉGIAS DE TESTES

Os testes automatizados foram escritos com o framework de testes do Django (TestCase), executados contra um banco de dados em memória isolado do ambiente de produção. Cada teste é nomeado com o número do item do check-list ao qual se refere, o que permite rastrear diretamente a cobertura de cada requisito.

A suíte cobre os cinco blocos entregues: autenticação e gestão de credenciais, recuperação de senha, criptografia e comunicação segura, conformidade com a LGPD e auditoria e logs — incluindo um teste dedicado que garante que nenhum evento de auditoria é perdido silenciosamente durante o fluxo de exclusão de conta.

Como o edital exige que os requisitos sejam testados e demonstrados obrigatoriamente através do front-end, os testes automatizados foram complementados por testes manuais na aplicação em produção, documentados pelos prints reunidos na seção 4.2, e pela execução do comando verificar_logs, que confirma publicamente a integridade da cadeia de hash da trilha de auditoria.

5.2 RESULTADOS OBTIDOS

Na versão entregue, a suíte de testes automatizados soma 162 testes, todos aprovados, cobrindo os cinco blocos de requisitos do check-list.

Durante a validação manual do bloqueio por força bruta, a equipe identificou que o django-axes estava, por padrão, bloqueando apenas por endereço IP, e não por conta — porque o nome do campo de usuário do formulário de login não coincidia com o esperado pela biblioteca. A correção (parâmetro AXES_USERNAME_FORM_FIELD) foi validada com

uma consulta direta ao banco de dados, comparando o campo username do registro de bloqueio antes e depois do ajuste — episódio documentado aqui como evidência de que os testes de segurança não se limitaram a verificar se a funcionalidade existia, mas se ela se comportava como especificado.

6 CONSIDERAÇÕES FINAIS

6.1 CONCLUSÃO

O projeto Health In Sight entregou, até o momento, os cinco blocos de requisitos de segurança e conformidade previstos no check-list da disciplina: autenticação e gestão de credenciais, recuperação de senha, criptografia e comunicação segura, conformidade com a LGPD e auditoria e logs — todos implementados, testados automaticamente e validados manualmente em produção.

O principal aprendizado da equipe foi que segurança da informação não se resume à escolha do algoritmo certo, mas à forma como os componentes se comportam em conjunto: o caso do bloqueio por força bruta, que funcionava sem cumprir a especificação até um teste manual revelar a falha, ilustra por que a validação funcional é indispensável mesmo quando a biblioteca usada é confiável.

Como próximos passos, o catálogo de conteúdos de saúde, o prazo de retenção dos registros de auditoria e a produção dos artefatos científicos finais (resumo e pôster) permanecem como itens em aberto para a etapa seguinte do projeto, assim como o R06 e a parte dos riscos R02 e R04 que depende de configuração nos painéis do Render, do Aiven e do GitHub, descrita no roteiro de operação do repositório (docs/operacao.md).

REFERÊNCIAS

AIVEN. Cloud security. [S. l.]: Aiven, 2026. Disponível em: https://aiven.io/docs/platform/concepts/cloud-security. Acesso em: 20 out. 2026.

BIRYUKOV, A.; DINU, D.; KHOVRATOVICH, D.; JOSEFSSON, S. **RFC 9106**: Argon2 memory-hard function for password hashing and proof-of-work applications. [S. l.]: IETF, 2021. Disponível em: https://www.rfc-editor.org/rfc/rfc9106. Acesso em: 18 out. 2026.

BRASIL. Lei nº 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais (LGPD). **Diário Oficial da União**: seção 1, Brasília, DF, p. 59, 15 ago. 2018.

DJANGO SOFTWARE FOUNDATION. **Django documentation**: version 5.2. [S. l.], 2025. Disponível em: https://docs.djangoproject.com/en/5.2/. Acesso em: 18 out. 2026.

INTERNATIONAL ORGANIZATION FOR STANDARDIZATION. **ISO/IEC 27001:2022**: information security, cybersecurity and privacy protection: information security management systems: requirements. Geneva: ISO, 2022.

M'RAIHI, D.; MACHANI, S.; PEI, M.; RYDELL, J. **RFC 6238**: TOTP: time-based one-time password algorithm. [S. l.]: IETF, 2011. Disponível em: https://www.rfc-editor.org/rfc/rfc6238. Acesso em: 18 out. 2026.

NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY (NIST). **SP 800-63B**: digital identity guidelines: authentication and lifecycle management. Gaithersburg: NIST, 2017.

OWASP FOUNDATION. **Password storage cheat sheet**. [S. l.]: OWASP, 2023. Disponível em: https://cheatsheetseries.owasp.org/cheatsheets/Password_Storage_Cheat_Sheet.html. Acesso em: 18 out. 2026.

SCHNEIER, B.; KELSEY, J. Secure audit logs to support computer forensics. **ACM Transactions on Information and System Security**, New York, v. 2, n. 2, p. 159-176, maio 1999.

WORLD HEALTH ORGANIZATION. **Infodemic**. Geneva: WHO, [20--]. Disponível em: https://www.who.int/health-topics/infodemic. Acesso em: 18 out. 2026.